

A THREE-PART SERIES · APRIL–MAY 2026

Human Oversight of Agentic AI

Guardrails, the borrowed vocabulary of human-in-the-loop, and where the human actually goes in a banking system that composes tools and executes plans at machine speed.

PART 1

What 'Guardrail' Actually
Means

PART 2

Human-in-the-Loop Is a
Borrowed Term

PART 3

Where to Put the Human

Three connected questions

What is a guardrail?

1

A runtime intervention mechanism — not a test, not a metric. Banks conflate the three and end up with systems that look governed and aren't.

What is HITL?

2

A 1978 teleoperation concept. The phrase appears in exactly one principal US financial-services supervisory document.

Where does the human actually go?

3

Three timing regimes — design-time, deploy-time, runtime — each with different controls and failure modes. Knight Capital is the proof case.

What 'Guardrail' Actually Means

Everyone uses the word. Almost no one means the same thing. In an agentic system operating inside a bank, that ambiguity stops being academic.

Definitional sprawl, not just a comms problem

FINREGLAB · 2025 MARKET SCAN ON AGENTIC AI

"Guardrails [are] constraints to restrict the function of individual agents **and** ongoing monitoring and troubleshooting."

A runtime intervention mechanism bundled with a post-hoc observation function in a single definition.

If your security team thinks guardrails are tests and your model risk team thinks they're monitoring metrics, you end up with systems that look governed and aren't.

Runtime is the line

TESTS

Development phase

Verify binary correctness against known inputs. Pass/fail before deployment.

METRICS

Aggregate performance

F1, toxicity rates, hallucination frequencies. Feed retraining and audit review. Quantify trust over time.

GUARDRAILS

Runtime intervention

Intercept, evaluate, and pass or block a model's behavior *while it's happening*, before it reaches a user or downstream system.

A metric tells you hallucination risk is elevated in 3% of responses. A guardrail is what stops that 3% from going out.

Four categories, by where the control sits

CATEGORY	FOCUS	IMPLEMENTATION	FINANCIAL EXAMPLE
Input	Prompt integrity	Classifiers, regex, jailbreak detection	Block social engineering on loan-eligibility rules
Output	Safety & reliability	Hallucination checks, toxicity filters, PII redaction	Prevent account numbers appearing in chatbot responses
Tool	Execution safety	Allowlists, parameter validation, RBAC	Block wire transfers above threshold without human approval
Structural	Data integrity	Schema validation (JSON/XML), type checking	Confirm trade execution data is formatted for settlement systems

The mapping is messier than vendor whitepapers admit

CONCEPTUAL SOUNDNESS

Choice of mechanism

A second LLM as real-time safety classifier is a fundamentally different design decision than a deterministic rule-based filter. The guardrail itself goes through the same MRM process as the model it's guarding.

ONGOING MONITORING

Where the KPIs live

Frequency of intercepted jailbreaks, PII detection F1, drift in hallucination interception over time. Not the guardrail — the evidence the guardrail is working.

OUTCOMES ANALYSIS

The hardest translation

Backtesting that guardrails didn't suppress true positives or inflate false positives to a level that disrupts legitimate transactions. Materially different from backtesting a credit model.

THE UNADDRESSED GAP

Behavioral guardrails — prompt injection, jailbreaking, goal hijacking — have no validation framework. Banks implementing them are doing so without supervisory guidance on what "effective challenge" looks like for an

Probabilistic reasoning is useful and unsafe at the same time

GUARDRAIL TYPE	LATENCY	COST	ACCURACY FOR NUANCE
Deterministic (regex/rules)	< 5ms	Near zero	Low — keyword-based
Classifier-based (small model)	50–150ms	Low	Moderate
Reasoning (flash LLM)	200–500ms	Moderate	High
Reasoning (strong LLM)	1–3s	High	Very high

Under a 500ms latency budget, a strong reasoning model isn't viable as a real-time monitor. The practical solution is a cascade — a fast probe; an expensive classifier only when ambiguity is flagged.

Three problems we don't have answers for

01

Memory poisoning

Standard injection is session-scoped. Persistent memory creates a durable surface — a malicious instruction is retrieved, stored, and acted on across sessions.

02

A2A injection (XPIA)

A compromised low-privilege agent becomes a vector targeting a high-privilege transaction agent. Capability declarations and auth schemes are nascent.

03

Cascading failures

A single error propagates through a multi-agent network faster than human incident response can contain it. Closer to circuit-breaker failure than to anything in the MRM playbook.

Fifteen years of MRM practice didn't prepare anyone for adversarial targeting of memory-equipped agents with tool access. The institutional apparatus for that surface does not yet have an owner.

Human-in-the-Loop Is a Borrowed Term

A 1978 teleoperation concept that organizes most AI governance conversation in financial services — and that appears in almost no binding banking supervision text.

Sheridan & Verplank, MIT, 1978

- 1 No assistance: human takes all decisions and actions
- 2 Offers a complete set of decision alternatives
- 3 Narrows selection to a few
- 4 Suggests one alternative
- 5 Executes that suggestion if human approves
- 6 Allows human a restricted time to veto before auto-execution
- 7 Executes automatically, then necessarily informs the human
- 8 Informs the human only if asked
- 9 Informs the human only if it decides to
- 10 Decides everything, acts autonomously, ignoring the human

WHERE THE TERM CAME FROM

Remotely operated **undersea teleoperators**. A one-dimensional automation continuum that organized aviation and ML for three decades.

Parasuraman et al. (2000) decoupled *stage* from *degree*. That's why "HITL" now means different things at different points in a pipeline.

Bainbridge (1983): automation reliably creates the conditions for its own oversight failure.

Engineers and regulators use the same word for different controls

HITL

HUMAN-IN-THE-LOOP

Intervention in every decision cycle. Drifted in ML to mean labelers and preference-raters. In autonomous-weapons doctrine, humans select individual targets.

HOTL

HUMAN-ON-THE-LOOP

Human-supervised autonomy. Monitor and halt; don't drive. DoD Directive 3000.09 uses "semi-autonomous" rather than HOTL.

HOOTL

HUMAN-OUT-OF-THE-LOOP

Two meanings. Defense: lethal autonomous systems. Human factors: the performance decrement Bainbridge identified.

HIC

HUMAN-IN-COMMAND

EU HLEG 2019. Oversee the overall activity of the AI system and decide when and how to use it. Strongest oversight short of MHC.

MHC

MEANINGFUL HUMAN CONTROL

Article 36 (2013). Tracking condition + tracing condition. Strongest normative charge; rare in financial regulation.

HO

HUMAN OVERSIGHT

EU AI Act Art. 14. The regulatory workhorse. Understand limits, awareness of automation bias, intervene or stop.

"Human-in-the-loop" appears in exactly one principal US supervisory document

HITL CONCEPT	REGULATORY LANGUAGE	PRIMARY SOURCE
Independent human review	"Effective challenge"	SR 11-7 (2011); SR 26-2 (2026)
Authority to override AI	"Qualified personnel" with explicit authority to require changes	SR 11-7 §V
Human judgment in edge cases	"Expert judgment"; "conservative adjustments"	SR 11-7 §IV
Consumer fallback	"Human Alternatives...and Fallback"; offramp to a human representative	AI Bill of Rights (2022); CFPB Chatbots Spotlight (2023)
Adverse action explainability	"Specific and accurate reasons"	CFPB Circ. 2023-03; ECOA / Reg B
Deployable stop capability	"Kill-switch"	IOSCO FR06/2021; EU AI Act Art. 14(4) (e)

SR 26-2 (April 2026) excludes generative and agentic AI from scope. Banks applying these standards to agentic deployments are doing so by analogy — no governing directive, no guidance.

Three structural shifts oversight has to address

01

Opaque intermediate steps

Reasoning traces are chains of probabilistic outputs that don't reproduce under re-inspection. Post-hoc review cannot reconstruct how an output was reached.

02

Errors compound silently

Multi-agent errors propagate through natural-language context, not structured logs. A small reasoning error at step one outruns any monitoring flag.

03

Behavioral drift through state

Agentic systems update response patterns based on accumulated context. Validated behavior pre-deployment isn't guaranteed under novel inputs.

Not incremental from Knight Capital or the 2010 Flash Crash. These shifts change what oversight requires structurally. Coverage metrics are the wrong frame.

Where to Put the Human

HITL is a design problem with three timing regimes. Runtime monitoring cannot substitute for deploy-time governance. Knight Capital is the proof case.

Different humans. Different controls. Different failure modes.

DESIGN-TIME

Shape the model before customers see it

RLHF labelers and preference-raters bake oversight into behavior across all future deployments. Not a substitute for an operator checkpoint at inference time.

DEPLOY-TIME

Where SR 11-7's apparatus lived

MRM validation, conceptual soundness, effective challenge, red-team. Most banking vocabulary maps here. Clear expectations — written for static models.

RUNTIME

Approval gate. Interrupt. Kill switch.

What FINRA 2026 asks about. Different human, different control surface. The regime existing frameworks address *least* specifically.

A runtime checkpoint without deploy-time validation operates within bounds nobody has tested. Nothing in the runtime stack is set up to surface that gap.

And where the argument breaks

THE ARGUMENT

Modern observability replaces nine-month conceptual-soundness reviews

Continuous adversarial testing, hard deterministic guardrails at output, inference-time drift monitoring. A bank running these can claim a stronger evidentiary record than one with an 18-month-old documentation packet.

BPI April 2025 repeal letter. SR 26-2 partially accommodated by carving GenAI out of scope.

WHERE IT BREAKS

Runtime monitoring assumes the monitoring works

Whether the runtime mechanisms function under load is a deploy-time question. Someone needs the technical depth, the incentives to ask, and the authority to delay rollout if the answer is no.

Plus action classes where individual decisions hit consumers and become irreversible before any monitor fires: RTP / FedNow settle in seconds with no chargeback mechanism.

Knight Capital had HITL — on paper

MECHANISM 1 · ALERT PIPELINE

97 "Power Peg disabled" emails

Sent in the 89 minutes before market open. Not designed as system alerts. No one acted.

MECHANISM 2 · RUNTIME MONITORING

PMON real-time position monitor

Manually surveilled raw data. Generated no automated alerts. Useless at the transaction volume that followed.

45 MINUTES AFTER THE OPEN

LOSS

\$460M

TRADES EXECUTED

4M

STOCKS AFFECTED

154

SEC: Knight's controls were "**not reasonably designed**" to manage the risk of its market access.

Three deploy-time questions a challenge function would have asked

COMPETENCE

Would 97 emails surface as a stop signal?

Did anyone model the alert pipeline against operator cognitive load? At Knight, validators with that depth were absent from the deployment review.

INFLUENCE

Who could stop trading, on what evidence?

Was there a written, rehearsed escalation procedure with a named owner? Authority on paper is not authority in practice.

INCENTIVES

Could validation ask the uncomfortable question?

"What is PMON's throughput ceiling at the open of an unusually heavy day?" Speed-to-market pressure is the structural condition under which the question doesn't get asked.

None of these can be answered by runtime monitoring after the fact. A runtime-only posture leaves them structurally orphaned. The failure mode is Knight's.

Designing a rubber stamp with better documentation

ACPR · 2020

Behavioral asymmetry

Humans feel greater responsibility when *contradicting* an algorithm than when *confirming* it. The path of least cognitive resistance at the checkpoint is approval.

BEA · AIR FRANCE 447 (2012)

The diagnostic deficit

Autopilot disconnected correctly. HITL worked as specified. Years of reliable automation had eroded the crew's competence in the manual control they were handed.

JAMIA · 74-STUDY META-ANALYSIS (2012)

10–15%

Override rates rarely exceed this — even when participants know they're being studied. A 5% override rate is the appearance of oversight, not the function.

A documented HITL where a human approved a bad output becomes evidence of the bank's role — not a defense against it. The legal exposure is arguably worse than no checkpoint at all.

Three international templates worth tracking

MAS · NOV 2025 (DRAFT)

Quantum = f(autonomy, complexity, reliance)

Scales required oversight to potential impact and degree of autonomy. Names the variables without resolving the function — calibration remains institution-by-institution.

OSFI E-23 · MAY 2027

Autonomy as a model-risk rating factor

Feeds the oversight question directly into the model's overall risk tier, rather than treating it as a separate operational control. Categorically different framing.

BAFIN · 2021

Reversibility windows

Human involvement intensifies as output diverges from baseline. Decisions should remain reversible within defined windows — the most operational expression of proportionality, and the element most directly relevant to agentic payment systems.

An updated risk-tier row reads: "Deploy-time: quarterly validation + ongoing monitoring; Runtime: mandate-scope interrupt before wire / RTP execution; Reversibility: ACH alternative required before irrevocable rail commitment." The checkbox summarizes the design rather than substituting for it.

The supervisory question for agentic AI

Not whether a human is in the loop. Whether the loop still runs at a speed and transparency at which human judgment can matter — and what to do when the answer is no.

PART 1

Runtime intervention

Tests are dev-phase. Metrics are aggregate. A guardrail intercepts live behavior. Conflating them produces instrumented systems that still fail.

PART 2

A 1978 borrowed term

Banking's actual vocabulary is "effective challenge," "qualified personnel," "human oversight." SR 26-2 excludes generative and agentic AI from scope.

PART 3

Three regimes, calibrated together

Runtime monitoring cannot answer the deploy-time question of whether runtime mechanisms will hold under load. Knight Capital is what happens when no one owns that question.